Semana 02 — Criptografía aplicada y gestión de secretos

Fase 1: Fundamentos, criptografía y marco legal — instrucciones paso a paso

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	02 de 10
Fase	1 — Fundamentos, criptografía y marco legal
Modalidad	4 grupos, trabajo desde sus propios equipos
Dedicación	4 horas de laboratorio + 2 horas de estudio independiente
Instrumento	Actividad formativa
Entrega	GitHub, carpeta semana_02/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Antes de la sesión

Estas tareas se hacen en casa, antes de la práctica. Si el repositorio o el laboratorio no están listos al empezar, la sesión se va en arreglarlos y no alcanza para el informe.

1. Comprobar que el repositorio del grupo tiene la carpeta semana_02 creada.
2. Revisar la retroalimentación del docente sobre la semana anterior y corregir lo pendiente.
3. Traer instaladas las herramientas de la semana: openssl, sha256sum, Python hashlib.
4. Confirmar que el laboratorio arranca y que los tres servicios responden antes de la sesión.
5. Leer el objetivo y los contenidos para llegar con el vocabulario de la práctica.

2 Objetivo de la semana

Aplicar cifrado simétrico y asimétrico, funciones hash y derivación de claves, y diagnosticar una configuración TLS insegura.

3 Contenidos que se aplican

- Cifrado simétrico AES en modos GCM y CBC, y por qué GCM aporta integridad.
- Cifrado asimétrico RSA y curvas elípticas; intercambio de claves.
- Hash criptográfico, HMAC y funciones de derivación PBKDF2 y Argon2.
- TLS 1.2 y 1.3, cadena de certificados y errores de validación.
- Gestión de secretos y detección de claves en repositorios.

4 Escenario

Cada grupo cifra y descifra un archivo, firma y verifica un mensaje, inspecciona un certificado real y mide el coste de derivar una clave con distinto número de iteraciones.

5 Paso a paso de la práctica

1. Cifrar y descifrar un archivo con AES-256-GCM y verificar que un byte alterado rompe la integridad.
2. Generar un par de claves, firmar un mensaje y verificar la firma; después alterar el mensaje y comprobar el fallo.
3. Extraer e inspeccionar el certificado de un sitio real, identificando emisor, validez y algoritmo.
4. Medir el tiempo de PBKDF2 con 10000, 100000 y 600000 iteraciones y tabular el resultado.
5. Documentar qué primitiva resuelve confidencialidad, integridad y autenticidad en cada caso.

Concepto clave

Regla de oro de la evidencia: guarda la salida de cada paso en `semana_02/evidencia/` en el momento en que la obtienes. Reconstruirla después no es evidencia, es memoria.

Herramientas de la semana: openssl, sha256sum, Python hashlib.

6 Rol de cada grupo esta semana

Todos los grupos resuelven la misma práctica, cada uno en su propio repositorio y su propio laboratorio: el trabajo de un grupo no depende del de otro. El rol cambia el énfasis del trabajo y lo que cada grupo aporta al comparar resultados en clase, al final.

Grupo	Rol	Aporte principal
Grupo 1	**Rojo**	Evidencia cruda en semana_02/evidencia y el apartado de reproducción del informe.
Grupo 2	**Azul**	La mitigación aplicada, el comando de verificación y la comparación de resultados.
Grupo 3	**Púrpura**	La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.
Grupo 4	**Legal y reporte**	La versión final del informe y la declaración explícita de lo que no se pudo verificar.

7 Qué se entrega

Registro de comandos, salidas y una tabla que asigne cada primitiva a la propiedad que garantiza.

Estructura de la carpeta `semana_02/`:

- README.md con integrantes, roles y tabla de semanas entregadas.
- semana_02/informe.md o informe.pdf con el entregable de esa práctica.
- semana_02/scripts/ con el código, con type hints y docstrings.
- semana_02/evidencia/ con salidas, capturas y hashes anonimizados.
- semana_02/README.md con el resumen de lo hecho y lo que no se pudo verificar.

Reglas que se verifican al corregir:

- Nada de secretos, tokens ni contraseñas en el repositorio; las claves van en .env ignorado.
- Nada de imágenes de disco, muestras de malware ni binarios: solo hashes y enlaces.
- Evidencia anonimizada: sin datos personales de terceros ni credenciales reales.
- Un commit por entrega con mensaje "semana NN: <entregable>".
- La práctica cuenta como entregada solo si está en el repositorio antes del corte.

8 Cómo se corrige

Criterio	Peso
Cifrado y descifrado correctos con verificación de integridad	3,0
Firma y verificación demostradas, incluido el caso alterado	2,5
Lectura correcta del certificado y de la cadena	2,0
Medición de KDF con conclusión sobre coste y seguridad	1,5
Explicación de qué propiedad cubre cada primitiva	1,0
Total	**10,0**

9 Lista de verificación antes del corte

- El repositorio del grupo existe, es privado y el docente aparece como colaborador.
- La carpeta semana_02/ está en el repositorio, no solo en el equipo.
- El informe explica qué se hizo, con qué comandos y qué se obtuvo.
- La evidencia está anonimizada: sin datos personales, credenciales ni secretos.
- Cada hallazgo tiene su hash o su salida cruda que permite reproducirlo.
- El commit ’semana 02: <entregable>’ está hecho antes del corte.

Alcance y autorización: solo se trabaja sobre los contenedores del laboratorio o sobre sistemas con autorización escrita. Si el objetivo no está en ese conjunto, se detiene la práctica y se consulta al docente. El uso de estas técnicas fuera del alcance tiene consecuencias académicas y legales.

Recuerda

Dudas de la semana: se responden en clase o en el repositorio. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

10 Glosario de la semana

Término	Definición
Cifrado simétrico	Cifrado que usa la misma clave para cifrar y descifrar. Es rápido y adecuado para volumen, pero exige repartir la clave por un canal seguro.
Cifrado asimétrico	Cifrado con un par de claves: la pública cifra o verifica y la privada descifra o firma. Resuelve el reparto de claves a cambio de ser más lento.
Hash criptográfico	Función de un solo sentido que produce una huella de tamaño fijo; cambiar un byte cambia la huella. No cifra ni se puede revertir.
HMAC	Hash con clave que autentica un mensaje y detecta manipulación. Aporta integridad y autenticidad de origen, no confidencialidad.
Derivación de claves	Convertir una contraseña o secreto débil en una clave del tamaño adecuado con un coste deliberado (PBKDF2, Argon2) para frenar la fuerza bruta.
TLS	Protocolo que cifra y autentica una conexión entre cliente y servidor. HTTPS es HTTP sobre TLS.
Cadena de certificados	Secuencia de certificados firmados que enlaza la clave del servidor con una autoridad de confianza. Si falta un eslabón o es inválido, la validación falla.
Gestión de secretos	Crear, almacenar, rotar y revocar claves y contraseñas sin dejarlas en el código, en los argumentos ni en el historial de git.